# NIST CSF 2.0
# Cybersecurity Advisory Report

**Apex Scientific Systems** | Fictional organization | Portfolio simulation

**Important limitation: This is an advisory readiness assessment for a fictional organization. It is not an independent audit, certification, attestation, or official NIST score.**

## Executive summary

The advisory assessment identified foundational strengths in business continuity, backups, network security, physical safeguards, endpoint standardization, and parts of malware protection. Material gaps remain in governance, cybersecurity risk management, identity and access management, supplier oversight, data protection, security monitoring, and incident response.

The priority is to establish accountable governance and reduce immediate account-compromise and detection risk before investing in broader program maturity.

| Priority | Advisory focus | Recommended outcome |
|---|---|---|
| 1 | Governance and accountability | Defined security leadership, approved policy, assigned roles, and board oversight |
| 2 | Identity and privileged access | MFA, unique administrator accounts, least privilege, and recurring access reviews |
| 3 | Detection and response | Centralized logging, SIEM monitoring, response plans, and tested playbooks |
| 4 | Risk and supplier management | Cyber risk register, treatment process, supplier tiering, and due diligence |
| 5 | Data and vulnerability protection | Classification, DLP, controlled removable media, and formal remediation |

## 1. Cybersecurity governance

• Appoint a cybersecurity manager or designate an accountable security leader with appropriate authority and resources.

• Define cybersecurity roles and responsibilities, including senior-management and board obligations.

• Approve a comprehensive information security policy and establish a recurring management-review cycle.

• Build a proportionate security operating model using internal staff, qualified contractors, or a managed provider.

## 2. Identity and access management

• Implement multifactor authentication across the organization, prioritizing privileged, remote-access, cloud, and critical business accounts.

• Eliminate shared administrator passwords and issue individually attributable privileged accounts.

• Apply least privilege, separation of duties, role-based access, and formal joiner-mover-leaver procedures.

• Perform recurring access reviews and document approvals, exceptions, and remediation.

## 3. Detection and incident response

• Implement centralized security logging and a SIEM capability, either internally or through a managed security service provider.

• Create an enterprise incident-response plan with ownership, escalation, evidence preservation, communications, recovery, and lessons learned.

• Develop and exercise playbooks for at least five likely scenarios, such as phishing, ransomware, account compromise, malware, and data exposure.

## 4. Cybersecurity risk management

• Establish a repeatable process to identify, analyze, treat, accept, monitor, and report cybersecurity risks.

• Maintain a cybersecurity risk register with likelihood, impact, priority, treatment, ownership, target dates, and residual risk.

• Obtain audit and risk committee endorsement for risk appetite, escalation thresholds, and reporting cadence.

• Include cybersecurity within the internal audit or independent assurance program.

### 5. Asset and vulnerability management

• Identify and classify hardware, software, cloud services, information assets, and owners based on criticality and sensitivity.

• Maintain an accurate asset inventory or CMDB and review it periodically.

• Formalize vulnerability scanning, risk-based prioritization, remediation timeframes, exception handling, and verification of closure.

• Prioritize the high and severe vulnerabilities already identified.

### 6. Third-party risk management

• Create a supplier-risk process covering identification, tiering, due diligence, contracting, monitoring, reassessment, and offboarding.

• Prioritize suppliers that process sensitive data or support critical operations.

• Include security requirements, breach notification, access control, resilience, audit rights, and termination obligations in contracts.

### 7. Data security and DLP

• Perform data discovery and classify information by sensitivity, business impact, and legal or contractual requirements.

• Apply Microsoft Purview Information Protection or an equivalent labeling capability appropriate to the Microsoft environment.

• Implement proportionate data-loss-prevention controls for email, collaboration, endpoints, and cloud storage.

• Restrict removable media by default and authorize temporary exceptions only when a documented business need exists.

### 8. Security education and awareness

• Require security awareness training at onboarding and at least annually thereafter.

• Run periodic phishing simulations and targeted follow-up training based on results.

• Track completion, reporting behavior, repeat failures, and corrective actions as measurable program indicators.

## Suggested sequencing

**0-30 days:** assign accountability, approve immediate MFA and privileged-access actions, remediate severe vulnerabilities, and draft the incident-response plan.

**31-90 days:** establish the risk register, supplier inventory, centralized logging roadmap, security policy set, access reviews, and recurring awareness program.

**90-180 days:** implement SIEM monitoring, formalize data classification and DLP, exercise response playbooks, and begin management reporting and independent review.

Prepared by Richard Vincent as an educational GRC portfolio project.